

INFORME DE PENTESTING

Análisis Forense de Integridad de Ficheros

Laboratorio «Encrypted Data Leak»

WHOAMI-LABS • Entorno de prácticas autorizado

Laboratorio	Encrypted Data Leak
Plataforma	WHOAMI-LABS.COM
Dificultad	Fácil (1 punto)
Objetivo (IP)	172.17.0.2
Tipo de ejercicio	Forense / Integridad de ficheros
Fecha de ejecución	05 de octubre de 2026
Resultado	Completado — FLAG obtenida
Clasificación	Uso formativo

0. Aviso de autorización y alcance

Ejercicio autorizado

Todas las acciones descritas en este documento se han realizado íntegramente dentro de WHOAMI-LABS, una plataforma de formación que autoriza explícitamente la explotación de sus entornos. El sistema objetivo (172.17.0.2) es una máquina de laboratorio aislada, desplegada ad hoc para este ejercicio. No se ha atacado ningún sistema de terceros. Este informe tiene exclusivamente finalidad educativa.

A efectos didácticos, el ejercicio se documenta siguiendo la estructura de un encargo real (reglas de compromiso, alcance y autorización por escrito). En este caso:

- **Rules of Engagement (RoE):** acceso vía SSH e inspección del sistema de ficheros del laboratorio. Sin ataques destructivos ni denegación de servicio.
- **Alcance (scope):** único host 172.17.0.2, servicio SSH (22/tcp) y los ficheros del directorio /investigacion.
- **Autorización:** otorgada por la propia plataforma al desplegar el laboratorio.

1. Resumen ejecutivo

El objetivo del ejercicio era, simulando una investigación forense tras una supuesta fuga de datos, detectar qué ficheros de un servidor habían sido manipulados por un atacante y localizar un indicador oculto (la «FLAG») que confirmara el compromiso.

La metodología se basó en la verificación de integridad mediante funciones hash: se compararon los hashes actuales de cuatro ficheros de configuración con una línea base (baseline) de hashes originales. La comparación reveló que los cuatro ficheros habían sido modificados respecto a su estado original.

La inspección manual del contenido permitió aislar el fichero crítico, [access_logs.txt](#), en cuyos registros el atacante dejó rastro de actividad sospechosa y ocultó el indicador en una línea de depuración. El marcador recuperado fue:

FLAG recuperada

FLAG{D4t4_L34k_D3t3ct3d_2026}

Riesgo global del escenario simulado: ALTO. Se detectaron credenciales de base de datos en texto plano, manipulación no autorizada de ficheros de configuración y evidencias de un acceso no identificado seguido de un «restablecimiento» del sistema, patrón compatible con el borrado de huellas por parte de un atacante.

2. Metodología

El ejercicio se abordó respetando el orden de fases de una operación ofensiva real, mapeables a las tácticas de MITRE ATT&CK. Cada fase se documenta con sus comandos, resultados y evidencia gráfica.

Fase	Actividad	Herramienta principal
1	Reconocimiento y escaneo de puertos	Nmap
2	Acceso inicial al sistema	SSH
3	Verificación de integridad (hashing)	md5sum / diff
4	Inspección de ficheros	cat / grep
5	Identificación del IoC y de la FLAG	Análisis manual
6	Validación y reporte	WHOAMI-LABS

3. Desarrollo técnico

3.1 Fase 1 — Reconocimiento con Nmap

Se lanzó un escaneo completo de puertos TCP contra el host objetivo para identificar la superficie de ataque. Se emplearon detección de versiones, scripts por defecto y la totalidad del rango de puertos:

```
nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2
```

```
(kali㉿kali)-[~]
$ nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-05 15:22 +0200
Nmap scan report for 172.17.0.2
Host is up (0.0000020s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|_  256 18:9a:af:51:8c:2c:17:c6:bd:e7:38:8c:f9:8a:03:bf (ECDSA)
|_  256 4c:07:09:5b:12:12:b8:04:13:58:3b:55:8e:d6:98:f0 (ED25519)
MAC Address: 62:56:C0:E7:F4:D3 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.64 seconds

(kali㉿kali)-[~]
$
```

Figura 1 — Resultado del escaneo Nmap sobre 172.17.0.2

Resultado: el host está activo y expone un único servicio, **SSH en el puerto 22/tcp** (OpenSSH 8.9p1 sobre Ubuntu). Los otros 65.534 puertos aparecen cerrados. La superficie de ataque, por tanto, se reduce al servicio SSH.

3.2 Fase 2 — Acceso inicial vía SSH

El laboratorio proporciona las credenciales de acceso al desplegarse. Antes de conectar se limpió la clave de host antigua para evitar conflictos de verificación:

```
ssh-keygen -f '/home/kali/.ssh/known_hosts' -R '172.17.0.2'
ssh estudiante@172.17.0.2
```

Password: student2026

```

kali@kali:~$ ssh-keygen -f '/home/kali/.ssh/known_hosts' -R '172.17.0.2'
# Host 172.17.0.2 found: line 3
# Host 172.17.0.2 found: line 4
/home/kali/.ssh/known_hosts updated.
Original contents retained as /home/kali/.ssh/known_hosts.old

(kali@kali)~$ ssh estudiante@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:ewsIqLS6/MVWhgO6RvBL/Ytgiv3sZ3Elhxkez0K/2F0
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
estudiante@172.17.0.2's password:
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 7.1.5+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

ENCRIPTED DATA LEAK - LABORATORIO FORENSE

cd /investigacion
cat README.txt

estudiante@encrypted_data_leak:~$

```

Figura 2 — Despliegue del laboratorio y conexión SSH establecida

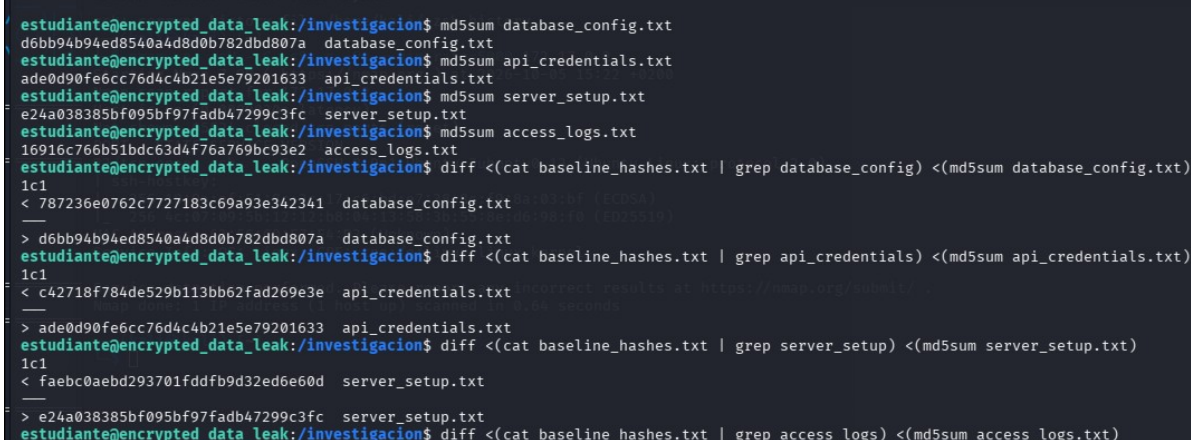
La conexión se establece correctamente con el usuario **estudiante**. Dentro del sistema, el fichero **README.txt** del directorio **/investigacion** detalla la misión: generar hashes de los cuatro ficheros actuales, compararlos con la línea base y localizar la FLAG en el fichero modificado.

3.3 Fase 3 — Verificación de integridad mediante hashes

Se calcularon los hashes MD5 de los cuatro ficheros de configuración y se compararon con los valores de la línea base mediante el comando diff. Una función hash produce una huella única del contenido: si un solo byte cambia, el hash cambia por completo.

```
md5sum database_config.txt api_credentials.txt server_setup.txt access_logs.txt

diff <(cat baseline_hashes.txt | grep database_config) <(md5sum
database_config.txt)
diff <(cat baseline_hashes.txt | grep api_credentials) <(md5sum
api_credentials.txt)
diff <(cat baseline_hashes.txt | grep server_setup) <(md5sum server_setup.txt)
diff <(cat baseline_hashes.txt | grep access_logs) <(md5sum access_logs.txt)
```



```
estudiante@encrypted_data_leak:/investigacion$ md5sum database_config.txt
d6bb94b94ed8540a4d8d0b782dbd807a database_config.txt
estudiante@encrypted_data_leak:/investigacion$ md5sum api_credentials.txt
ade0d90fe6cc76d4c4b21e5e79201633 api_credentials.txt
estudiante@encrypted_data_leak:/investigacion$ md5sum server_setup.txt
e24a038385bf095bf97fadb47299c3fc server_setup.txt
estudiante@encrypted_data_leak:/investigacion$ md5sum access_logs.txt
16916c766b51bdc63d4f76a769bc93e2 access_logs.txt
estudiante@encrypted_data_leak:/investigacion$ diff <(cat baseline_hashes.txt | grep database_config) <(md5sum database_config.txt)
1c1
< 787236e0762c7727183c69a93e342341 database_config.txt
> d6bb94b94ed8540a4d8d0b782dbd807a database_config.txt
estudiante@encrypted_data_leak:/investigacion$ diff <(cat baseline_hashes.txt | grep api_credentials) <(md5sum api_credentials.txt)
1c1
< c42718f784de529b113bb62fad269e3e api_credentials.txt
> ade0d90fe6cc76d4c4b21e5e79201633 api_credentials.txt
estudiante@encrypted_data_leak:/investigacion$ diff <(cat baseline_hashes.txt | grep server_setup) <(md5sum server_setup.txt)
1c1
< faebc0aebd293701fddfb9d32ed6e60d server_setup.txt
> e24a038385bf095bf97fadb47299c3fc server_setup.txt
estudiante@encrypted_data_leak:/investigacion$ diff <(cat baseline_hashes.txt | grep access_logs) <(md5sum access_logs.txt)
```

Figura 3 — Cálculo de hashes MD5 y comparación con la línea base

Criterio de interpretación: si diff no devuelve salida, los hashes coinciden y el fichero está intacto; si devuelve diferencias (líneas con «<» original y «>» actual), el fichero ha sido modificado.

Fichero	Hash baseline (original)	Hash actual	Estado
database_config.txt	787236e0762c...342341	d6bb94b94ed8...bd807a	MODIFICADO
api_credentials.txt	c42718f784de...269e3e	ade0d90fe6cc...201633	MODIFICADO
server_setup.txt	faebc0aebd29...6e60d	e24a038385bf...299c3fc	MODIFICADO
access_logs.txt	(difiere)	16916c766b5b...9bc93e2	MODIFICADO

Hallazgo clave

Los cuatro ficheros presentan hashes distintos a los de la línea base: todos fueron manipulados. El README advierte que, aunque todos fueron «tocados», solo uno contiene información crítica. El trabajo de análisis consiste precisamente en distinguir los cambios triviales del cambio relevante.

3.4 Fase 4 — Inspección del contenido de los ficheros

Confirmada la manipulación, se inspeccionó el contenido de los ficheros para localizar datos sensibles e información añadida por el atacante:

```
cat database_config.txt
cat server_setup.txt
```



```
estudiante@encrypted_data_leak:/investigacion$ cat database_config.txt
# Database Configuration File
# Last modified: 2025-12-15 14:30:22
# Author: System Admin
DB_HOST=192.168.1.100
DB_PORT=5432
DB_NAME=production_db
DB_USER=admin
DB_PASSWORD=SecurePass2025!
MAX_CONNECTIONS=100
TIMEOUT=30
BACKUP_ENABLED=true
estudiante@encrypted_data_leak:/investigacion$ cat server_setup.txt
# Server Configuration
# Date: 2025-12-18 16:45:10
# Environment: Production
SERVER_NAME=web-prod-01
IP_ADDRESS=10.0.2.50
OS_VERSION=Ubuntu 22.04 LTS
SSH_PORT=22
HTTPS_PORT=443
FIREWALL=enabled
MONITORING=active
LAST_BACKUP=2025-12-19
estudiante@encrypted_data_leak:/investigacion$ cat server_setup.txt
# Server Configuration
# Date: 2025-12-18 16:45:10
# Environment: Production
SERVER_NAME=web-prod-01
IP_ADDRESS=10.0.2.50
OS_VERSION=Ubuntu 22.04 LTS
SSH_PORT=22
HTTPS_PORT=443
FIREWALL=enabled
MONITORING=active
LAST_BACKUP=2025-12-19
estudiante@encrypted_data_leak:/investigacion$
```

Figura 4 — Contenido de database_config.txt y server_setup.txt

La inspección revela una exposición grave de datos sensibles en texto plano, que constituye por sí misma un hallazgo de seguridad relevante:

- **database_config.txt:** credenciales de base de datos en claro — usuario **admin** y contraseña **SecurePass2025!**, además de host (192.168.1.100), puerto y nombre de la BD de producción.
- **server_setup.txt:** configuración del servidor de producción (nombre de host, IP interna 10.0.2.50, puertos, estado de firewall y fecha del último backup).

3.5 Fase 5 — Identificación del IoC y de la FLAG

El fichero crítico resultó ser **access_logs.txt**. Su inspección expone la secuencia completa del incidente simulado:

```
cat access_logs.txt
# (alternativa de búsqueda directa)
```

```
grep -i "FLAG" *.txt
```

```
estudiante@encrypted_data_leak:/investigacion$ cat access_logs.txt
# System Access Logs
# Generated: 2025-12-21 11:22:45
# Security Level: High

[2025-12-21 08:15:23] User: admin - Login: SUCCESS
[2025-12-21 09:30:12] User: carlos - Login: SUCCESS
[2025-12-21 10:45:55] User: maria - Login: FAILED
[2025-12-21 11:20:33] User: system - Action: BACKUP_COMPLETED
[2025-12-21 11:22:40] User: unknown - Login: FAILED
[2025-12-21 11:22:41] ALERT: Suspicious activity detected
[2025-12-21 11:22:42] DEBUG_MODE: FLAG{D4t4_L34k_D3t3ct3d_2026}
[2025-12-21 11:22:43] System restored to normal operation
estudiante@encrypted_data_leak:/investigacion$
```

Figura 5 — Registros de acceso: actividad sospechosa y FLAG oculta

La línea temporal de los registros reconstruye el ataque:

- **11:22:40** — intento de login del usuario **unknown**: FAILED (acceso no identificado).
- **11:22:41** — ALERT: Suspicious activity detected (el sistema detecta la anomalía).
- **11:22:42** — DEBUG_MODE: **FLAG{D4t4_L34k_D3t3ct3d_2026}** — el indicador queda camuflado como si fuera una línea de depuración.
- **11:22:43** — «System restored to normal operation»: patrón típico de borrado de huellas tras el compromiso.

La FLAG recuperada es **FLAG{D4t4_L34k_D3t3ct3d_2026}**.

3.6 Fase 6 — Validación del hallazgo

Introducida la FLAG en el panel del laboratorio, la plataforma confirma la finalización correcta del ejercicio.

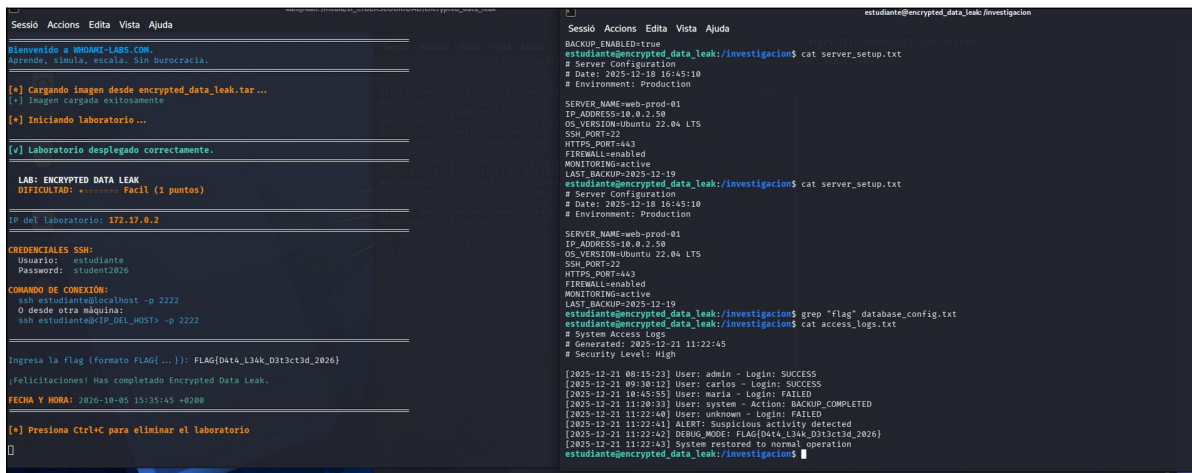


Figura 6 — Validación: laboratorio completado («¡Felicitaciones!»)

4. Resumen de hallazgos

ID	Hallazgo	Severidad
H-01	Credenciales de base de datos almacenadas en texto plano (admin / SecurePass2025!)	CRÍTICA
H-02	Manipulación no autorizada de ficheros de configuración (4 de 4 alterados)	ALTA
H-03	Acceso de usuario no identificado («unknown») seguido de restauración del sistema	ALTA
H-04	Información sensible de infraestructura expuesta (IPs internas, puertos, backups)	MEDIA
H-05	Indicador de compromiso oculto en registros bajo una línea de depuración	INFORMATIVA

5. Recomendaciones de remediación

- **Gestión de secretos:** eliminar credenciales en claro de los ficheros de configuración y migrarlas a un gestor de secretos (Vault, variables de entorno cifradas). Rotar de inmediato la contraseña expuesta.
- **Monitorización de integridad (FIM):** desplegar una solución tipo AIDE, Tripwire o Wazuh que calcule hashes periódicamente y alerte ante cambios no autorizados, automatizando lo hecho manualmente en este ejercicio.
- **Endurecimiento de SSH:** restringir el acceso por clave pública, deshabilitar login por contraseña y limitar los orígenes de conexión.
- **Centralización y protección de logs:** enviar los registros a un SIEM externo e inmutable, de modo que un atacante no pueda alterarlos ni «restaurar» el sistema para borrar huellas.
- **Respuesta ante incidentes:** definir un procedimiento que, ante una alerta de actividad sospechosa, preserve evidencias en lugar de restaurar el sistema automáticamente.

6. Conclusión

El ejercicio se completó con éxito, recuperando la FLAG FLAG{D4t4_L34k_D3t3ct3d_2026} y reconstruyendo la cronología del incidente simulado. Más allá del objetivo CTF, el laboratorio ilustra una técnica forense fundamental: la verificación de integridad mediante hashes permite detectar manipulaciones de ficheros de forma rápida y fiable, siempre que se disponga de una línea base de confianza.

La lección transferible a un entorno real es doble: por un lado, la importancia de mantener baselines de integridad y monitorizarlas de forma continua; por otro, la necesidad de proteger los registros frente a la manipulación, ya que un atacante que controla los logs puede ocultar su actividad tan fácilmente como se ocultó aquí la FLAG.